* Casestudy 1:

1. Bright mart is a medium sized online shoping company. customers use its and mobile app to purchase Products.

company Stores: Customer name, e-mail adresses, Phone numbers, Delivery adresses, passwords, order info, Payment related info.

Bright mart has around 100 employees.

* The company recently hired several new employees. To make things easier, the IT department gave employees access to different internal systems.

However, the company has the following security awareness.

- Some employees use simple Passwords such as Bright Mart123.
- Many employees use the same Passwords for multiple systems.
- Software updates are sometimes delayed.
- The company does not regularly conduct employee cybersecurity training.
- There is no multi-factor authentication for some important accounts.
- Employees can access sensitive info that they do not necessarily need for their jobs.
- Backups are performed only once a month.

The incident

One day morning, an employee named Rahul receives an email:

Subject: Urgent. Your account will be Suspended.

The email appears to come from the company's IT department.

It says:

"Your account will be suspended today. Click the link below and verify your Password, immediately".

Rahul Clicks the link.

The page looks almost identical to company's login page.

He enters his user name and P.S.

Rahul does not realise the website is controlled by an attacker.

The attacker now has Rahul's login credentials.

Stage

* ~~Step~~ 1 - Unauthorised Access.

- The attacker uses Rahul's creds. to access Bright mart's internal system.
- Because Rahul uses the same P.S. for another system, the attacker is also able ~~to~~ access ~~that~~ system.
- The attacker discovers that Rahul has access to customer information.
- The attacker downloads a large amount of customer data.

* What cybersecurity problem has occurred ?

* Stage 2 - Malware Attack.

- The attacker sends another email to Rahul containing a malicious attachment.
- Rahul opens the attachment.
- Malware is installed on his computer
- The malware begins communicating with the attacker's system.
- The attacker now attempts to move from Rahul's computer to other systems within Bright Marts.

Which vulnerability allowed the attacker to move further into the organisation?

* Stage 3: Ransomware.

Two days later, employees arrive at work and discover that they cannot access imp files. A new message appears on the screen.

" Your files have been encrypted. Pay the ransom to recover them ".

The company's customer database and several imp. business files are encrypted.

Unfortunately, the company's most recent backup is a month old.

Brightmarts website stops working.

Customers cannot place orders

The customer support team cannot access customer records.

* Stage 4 - Business Impact

Bright mart now faces several problems

Financial Impact

The company loses sales because its website is unavailable.

Data Impact

Customer information may have been stolen

Operational Impact

Employees cannot access important systems.

Reputation Impact

Customers lose confidence in the company.

Legal / compilance Impact

The company may face regulatory or legal consequences depending on what information was exposed and which laws apply.

Solution:

1)

—) · phishing.
· Credential theft.
· Unauthorized access.
· Data breach.

2) Which vulnerability

—) · Weak passwords
· Excessive user privileges
· Lack of MFA.
· Poor Network security.
· Lack of employee awareness.
· Outdated software.

3) Threats

—) · Phising
· malware
· Ransomware
· Credential theft.
· Unauthorised access
· Data theft.

5) Weakness

→ Weak Password: Easier to compromise

Password reuse: One stolen password gives access to multiple systems

No MFA: Stolen passwords may be enough to log in.

Lack of Training: Employees falls for phising

Delayed updates: Vulnerable software may be ~~exposed~~ explioted.

Excessive privileges: Attackers can access more data.

6. Was the info exposed?

→ Yes
customer information was accessed / & downloaded by the attacker.

7. Was the info changed or damaged?
→ Potentially Yes.
The attacker could modify or encrypt files.

8. Were systems available to legitimate users?

→ No.

9. What to do to avoid it?

→ . Use Strong passwords.

· Implement MFA.

· Provide regular cybersecurity awareness training.

· Conduct phishing awareness exercises.

· Keep software updated.

· Follow principle of least privilege.

· Segment important network.

· Maintain regular backups.

· Encrypt sensitive data.

· Deploy antivirus / endpoint protection

· Monitor suspicious login activity.

· Develop an incident-response plan.

10: Was phishing the only problem?

→ No

Phishing was the initial attack, but weakness such as ~~st~~ password reuse, lack of MFA, excessive privileges, poor backups, and insufficient training allowed the attack to become much more damaging.

11. What was the biggest vulnerability?

→ There is no single correct answer.

For example:

Lack of employee awareness was a major vulnerability because the attack started when Raghav clicked the phishing link.

Another example might be:

Poor backup practices were the biggest problem because Bright mart could not recover from Ransomeware".

31/3/26